

# IDOR : Ketika URL Bisa Jadi Kunci untuk Bobol Data Orang lain

## Pendahuluan

Dalam lanskap keamanan aplikasi web modern, kerentanan IDOR (Insecure Direct Object Reference) tergolong sebagai salah satu ancaman paling berbahaya namun sering terabaikan. Bayangkan Anda sedang berbelanja online dan tiba-tiba dapat mengakses riwayat pesanan, detail pembayaran, atau bahkan data pribadi pengguna lain hanya dengan memodifikasi beberapa karakter di URL. Inilah skenario klasik serangan IDOR yang telah menyebabkan kebocoran data masif pada berbagai platform digital.

Artikel ini akan mengupas tuntas tentang bagaimana serangan IDOR bekerja, potensi dampak yang ditimbulkan, dan strategi pencegahan yang efektif bagi pengembang. Memahami kerentanan ini menjadi krusial, terutama ketika OWASP (Open Web Application Security Project) secara konsisten memasukkan IDOR sebagai bagian dari daftar kerentanan aplikasi web paling kritis.

## Memahami Konsep IDOR

### Apa Itu IDOR?

IDOR (Insecure Direct Object Reference) terjadi ketika aplikasi mengekspos referensi ke objek implementasi internal, seperti file, direktori, record database, atau kunci, sebagai parameter URL atau form yang tidak tervalidasi dengan baik. Akibatnya, penyerang dapat memanipulasi referensi tersebut untuk mendapatkan akses tidak sah ke data orang lain.

Secara sederhana, IDOR terjadi ketika sebuah aplikasi menerima input dari pengguna yang mengacu langsung pada sumber daya atau objek (misalnya ID pengguna) tanpa melakukan verifikasi apakah pengguna tersebut berhak mengakses objek yang dimaksud.

### Anatomi Serangan IDOR

Untuk memahami lebih dalam, mari kita pelajari bagaimana serangan IDOR biasanya terjadi:

1. **Identifikasi Parameter:** Penyerang mengidentifikasi parameter di URL, form, atau cookie yang kemungkinan merujuk ke objek data.
2. **Manipulasi Nilai:** Penyerang memodifikasi nilai parameter ini untuk merujuk ke objek yang berbeda.
3. **Eksplorasi:** Jika aplikasi tidak memvalidasi akses dengan benar, penyerang berhasil mengakses data yang seharusnya tidak diizinkan.

Sebagai contoh, perhatikan URL berikut:

`https://example.com/account/statement?user_id=123`

Jika pengguna dengan ID 123 mencoba mengubah parameter menjadi `user_id=124`, dan berhasil melihat data pengguna dengan ID 124, maka aplikasi tersebut rentan terhadap IDOR.

## Contoh Kasus IDOR dalam Aplikasi Web

### Simulasi IDOR dalam Sistem Profil Pengguna

Untuk memahami bagaimana IDOR bekerja dan cara mencegahnya, mari kita lihat simulasi lengkap menggunakan kode PHP berikut:

#### Struktur Database

Database idor\_demo memiliki tabel users dengan struktur dan data sebagai berikut:

| id | name   | email              | role  |
|----|--------|--------------------|-------|
| 1  | Ujang  | ujang@example.com  | user  |
| 2  | Asep   | asep@example.com   | user  |
| 3  | Gracie | gracie@example.com | admin |

#### Kode Aplikasi

**db.php** - File koneksi database:

```
php
<?php

$host = "localhost";
$user = "root";
$pass = "";
$db = "idor_demo";

$conn = new mysqli($host, $user, $pass, $db);

if ($conn->connect_error) {
    die("Koneksi gagal: " . $conn->connect_error);
}
```

```
?>
```

**profile.php** - Halaman profil yang rentan terhadap IDOR:

```
php
```

```
<?php
```

```
include 'db.php';
```

```
// Ambil ID dari URL dan cast ke integer agar sedikit lebih aman
```

```
$id = isset($_GET['id']) ? (int) $_GET['id'] : 0;
```

```
$sql = "SELECT * FROM users WHERE id = $id";
```

```
$result = $conn->query($sql);
```

```
if ($result->num_rows == 1) {
```

```
    $user = $result->fetch_assoc();
```

```
    echo "<h2>Profil Pengguna (Versi Rentan)</h2>";
```

```
    echo "Nama: " . htmlspecialchars($user['name']) . "<br>";
```

```
    echo "Email: " . htmlspecialchars($user['email']) . "<br>";
```

```
    echo "Role: " . htmlspecialchars($user['role']) . "<br>";
```

```
} else {
```

```
    echo "User tidak ditemukan.";
```

```
}
```

```
?>
```

**profile\_secure.php** - Halaman profil dengan perlindungan terhadap IDOR:

```
php
```

```
<?php
```

```
session_start();
```

```
include 'db.php';
```

*// Simulasi: hanya user yang sedang login boleh akses datanya sendiri*

```
$user_id = $_SESSION['user_id'] ?? null;
```

```
$id = isset($_GET['id']) ? (int) $_GET['id'] : 0;
```

*// Validasi: ID di URL harus sesuai dengan sesi login*

```
if ($user_id === null || $id !== $user_id) {
```

```
    die("Akses ditolak. Anda tidak berhak melihat data ini.");
```

```
}
```

```
$sql = "SELECT * FROM users WHERE id = $id";
```

```
$result = $conn->query($sql);
```

```
if ($result->num_rows == 1) {
```

```
    $user = $result->fetch_assoc();
```

```
    echo "<h2>Profil Anda (Versi Aman)</h2>";
```

```
    echo "Nama: " . htmlspecialchars($user['name']) . "<br>";
```

```
    echo "Email: " . htmlspecialchars($user['email']) . "<br>";
```

```
    echo "Role: " . htmlspecialchars($user['role']) . "<br>";
```

```
} else {
```

```
    echo "Data tidak ditemukan.";
```

```
}
```

```
?>
```

**login\_simulasi.php** - Simulasi proses login:

php

<?php

```
session_start();
```

*// Simulasi login: user dengan ID 2 (asep)*

```
$_SESSION['user_id'] = 2;
```

```
echo "Login berhasil sebagai user ID: " . $_SESSION['user_id'];
```

```
echo "<br><a href='profile.php?id=2'>[Lihat Profil - Versi Rentan]</a>";
```

```
echo "<br><a href='profile_secure.php?id=2'>[Lihat Profil - Versi Aman]</a>";
```

```
echo "<br><a href='logout.php'>Logout</a>";
```

```
?>
```

**logout.php** - Proses logout:

```
php
```

```
<?php
```

```
session_start();
```

```
session_destroy();
```

```
header("Location: login_simulasi.php");
```

```
exit;
```

```
?>
```

## **Langkah-langkah Simulasi**

### **1. Menyiapkan Database:**

- Buat database MySQL bernama idor\_demo
- Buat tabel users dengan kolom: id, name, email, dan role
- Masukkan data pengguna seperti pada tabel di atas

### **2. Mengakses Aplikasi:**

- Jalankan login\_simulasi.php untuk melakukan "login" sebagai Asep (ID 2)
- Aplikasi akan menampilkan dua link: versi rentan dan versi aman

### **3. Pengujian Versi Rentan:**

- Klik link "Lihat Profil - Versi Rentan" untuk melihat profil Asep

- Ubah parameter URL dari id=2 menjadi id=1 (Ujang) atau id=3 (Gracie)
- Anda akan melihat bahwa versi rentan menampilkan data pengguna lain tanpa validasi

#### 4. Pengujian Versi Aman:

- Klik link "Lihat Profil - Versi Aman" untuk melihat profil Asep
- Ubah parameter URL dari id=2 menjadi id=1 atau id=3
- Versi aman akan menampilkan pesan "Akses ditolak" karena adanya validasi

### Penjelasan Simulasi

#### 1. Skenario Awal:

- Database berisi tiga pengguna: Ujang (user), Asep (user), dan Gracie (admin)
- User dengan ID 2 (Asep) berhasil login melalui login\_simulasi.php
- Session menyimpan ID pengguna yang sedang login (\$\_SESSION['user\_id'] = 2)

#### 2. Versi Rentan (profile.php):

- Ketika Asep mengklik link "Lihat Profil - Versi Rentan", dia melihat profilnya dengan URL profile.php?id=2
- Dalam versi rentan, aplikasi hanya mengambil parameter id dari URL tanpa memeriksa apakah pengguna yang sedang login berhak melihat data tersebut
- **Eksplorasi IDOR:** Asep dapat dengan mudah mengubah parameter URL menjadi profile.php?id=1 (Ujang) atau profile.php?id=3 (Gracie) dan melihat data pengguna lain, termasuk email dan role admin
- Aplikasi akan menampilkan data pengguna dengan ID yang diminta tanpa validasi otorisasi

#### 3. Versi Aman (profile\_secure.php):

- Ketika Asep mengklik link "Lihat Profil - Versi Aman", dia melihat profilnya dengan URL profile\_secure.php?id=2
- Dalam versi aman, aplikasi melakukan validasi dengan membandingkan ID di URL dengan ID pengguna dalam session
- **Pencegahan IDOR:** Jika Asep mencoba mengubah parameter URL menjadi profile\_secure.php?id=1 atau profile\_secure.php?id=3, aplikasi akan menampilkan pesan "Akses ditolak"

- Validasi `if ($user_id === null || $id !== $user_id)` memastikan pengguna hanya dapat melihat datanya sendiri

### **Cara Pencegahan IDOR dalam Kode**

Dari kode simulasi di atas, kita dapat mengidentifikasi beberapa teknik pencegahan IDOR yang diterapkan dalam `profile_secure.php`:

#### **1. Verifikasi Identitas Pengguna:**

`php`

```
$user_id = $_SESSION['user_id'] ?? null;
```

```
$id = isset($_GET['id']) ? (int) $_GET['id'] : 0;
```

Aplikasi memastikan pengguna telah login (memiliki session) dan mengambil ID pengguna dari session, bukan hanya dari input pengguna.

#### **2. Validasi Akses Berdasarkan Kepemilikan:**

`php`

```
if ($user_id === null || $id !== $user_id) {
```

```
    die("Akses ditolak. Anda tidak berhak melihat data ini.");
```

```
}
```

Bagian ini adalah kunci utama pencegahan IDOR. Aplikasi memeriksa apakah ID yang diminta (dari URL) sesuai dengan ID pengguna yang sedang login. Jika tidak sesuai, akses ditolak.

#### **3. Penggunaan Session untuk Menyimpan Status Autentikasi:**

`php`

```
session_start();
```

```
// ...menggunakan $_SESSION['user_id']
```

Aplikasi menggunakan session untuk melacak identitas pengguna yang telah terautentikasi, bukan hanya mengandalkan parameter dari URL.

Simulasi ini menunjukkan dengan jelas perbedaan antara aplikasi yang rentan terhadap IDOR dan aplikasi yang menerapkan perlindungan yang tepat. Prinsip utama dalam pencegahan IDOR adalah selalu memvalidasi bahwa pengguna yang sedang login memiliki hak untuk mengakses resource yang diminta, tidak hanya mengandalkan parameter input yang dapat dimanipulasi oleh pengguna.

### **Dampak Serangan IDOR**

Kerentanan IDOR memiliki dampak serius yang meliputi:

## **1. Kebocoran Data Sensitif**

Penyerang dapat mengakses informasi pribadi pengguna lain seperti nama lengkap, alamat, nomor telepon, hingga detail keuangan. Pada kasus yang lebih parah, informasi seperti scan KTP, paspor, atau dokumen identitas lain juga bisa terekspos.

## **2. Modifikasi Data Tidak Sah**

Selain mengakses data, IDOR dapat memungkinkan penyerang untuk mengubah data pengguna lain, termasuk:

- Mengubah alamat email atau password
- Memodifikasi detail pesanan atau transaksi
- Mengubah pengaturan akun

## **3. Pelanggaran Privasi Masif**

Jika kerentanan IDOR terjadi pada sistem dengan jutaan pengguna, akibatnya bisa sangat masif. Eksploitasi otomatis dengan script sederhana dapat mengumpulkan data pengguna secara sistematis, yang kemudian bisa dijual di pasar gelap.

## **4. Kerugian Finansial dan Reputasi**

Bagi perusahaan, serangan IDOR dapat mengakibatkan:

- Denda regulasi akibat pelanggaran undang-undang privasi seperti GDPR atau UU PDP
- Biaya forensik dan remediasi keamanan
- Kerusakan reputasi jangka panjang
- Potensi gugatan hukum dari pengguna yang terdampak

## **Teknik Deteksi IDOR**

Mendeteksi kerentanan IDOR memerlukan pendekatan sistematis:

### **1. Manual Testing**

Tester keamanan dapat mencoba memodifikasi parameter secara manual dan mengamati respons sistem. Beberapa teknik meliputi:

- Mengganti ID pengguna di URL, cookies, atau hidden fields
- Mengakses resource dengan ID secara sekuensial (ID-1, ID+1)
- Mencoba mengakses resource dengan ID pengguna lain yang diketahui

### **2. Automated Tools**

Beberapa alat otomatis dapat membantu mengidentifikasi potensi IDOR:

- OWASP ZAP (Zed Attack Proxy)
- Burp Suite Professional dengan ekstensi Autorize
- Acunetix Web Vulnerability Scanner

### **3. Code Review**

Audit kode secara manual untuk pola-pola berisiko, seperti:

- Pengambilan parameter ID langsung dari input pengguna
- Kurangnya validasi akses pada endpoint yang menampilkan data

### **Strategi Pencegahan IDOR**

Untuk mencegah kerentanan IDOR, pengembang aplikasi dapat menerapkan beberapa strategi berikut:

1. Implementasi Kontrol Akses yang Kuat
2. Penggunaan Indirect Reference Maps
3. Validasi Input dan Autorisasi pada Setiap Endpoint
4. Enkripsi atau Hashing Parameter ID
5. Implementasi System Logging dan Monitoring

### **Kesimpulan**

Kerentanan IDOR merupakan ancaman serius yang dapat mengakibatkan kebocoran data sensitif dan pelanggaran privasi pengguna. Meskipun tergolong kesalahan mendasar dalam pengembangan aplikasi, IDOR masih sering ditemukan bahkan pada platform besar.

Bagi pengembang, pencegahan IDOR harus menjadi prioritas utama dalam setiap tahap pengembangan aplikasi. Implementasi kontrol akses yang ketat, validasi otorisasi pada setiap endpoint, dan penggunaan referensi tidak langsung dapat secara signifikan mengurangi risiko.

Bagi pengguna, waspada terhadap URL yang mengandung parameter ID atau referensi objek yang terlihat jelas. Meskipun keamanan aplikasi adalah tanggung jawab utama pengembang, kesadaran pengguna juga berperan penting dalam ekosistem keamanan digital yang komprehensif.

Dengan pemahaman yang tepat tentang kerentanan IDOR dan strategi pencegahannya, kita dapat berkontribusi dalam menciptakan lingkungan digital yang lebih aman dan melindungi privasi pengguna.

## Referensi

1. OWASP Foundation. (2021). A01:2021—Broken Access Control. OWASP Top 10. Tersedia di: [https://owasp.org/Top10/A01\\_2021-Broken\\_Access\\_Control/](https://owasp.org/Top10/A01_2021-Broken_Access_Control/) (Diakses pada: 29 April 2025).
2. PortSwigger Web Security Academy. Insecure Direct Object References (IDOR). Tersedia di: <https://portswigger.net/web-security/access-control/idor> (Diakses pada: 29 April 2025).
3. Secure Code Network. (2023). Penjelasan sederhana tentang IDOR (insecure direct object reference) | Web Penetration Testing [Video YouTube]. Tersedia di: <https://youtu.be/B1eOadGZ7sQ?si=7glwIGQnrxdZBUj> (Diakses pada: 30 April 2025).
4. Pejuang Siber. (2023). Membongkar Celah IDOR: Akses Data Rahasia Tanpa Login! [Video YouTube]. Tersedia di: <https://youtu.be/N7StY5aPTTU> (Diakses pada: 30 April 2025).